

RESUMEN CONCEPTOS DE SEGURIDAD DE LOS SISTEMAS DE INFORMACIÓN

Conceptos de seguridad de los sistemas de información.....	1
Definiciones Fundamentales	1
Metodologías y Estándares	2
Seguridad física y lógica	3
Seguridad Física	3
Seguridad Lógica	4
Amenazas y vulnerabilidades.....	4
Taxonomía de Amenazas y Ataques.....	4
Tipos de Ataques Específicos.....	5
Técnicas criptográficas y protocolos seguros.....	5
Clasificación de la Criptografía	5
Funciones Hash	5
Protocolos Seguros	6
Cifrado Híbrido y Salting de contraseñas	6
Mecanismos de firma digital.....	6
Infraestructura física de un CPD	7
Acondicionamiento y Racks.....	7
Clasificación (Tiers) según TIA-942.....	8
Sistemas de gestión de incidencias y Control remoto	8
Gestión de Incidencias (ITIL).....	8
Control Remoto	8
Soluciones del CCN-CERT.....	9

Conceptos de seguridad de los sistemas de información

Definiciones Fundamentales

- **Seguridad:** "Capacidad de las redes o de los sistemas de información de resistir, con un determinado nivel de confianza, los accidentes o acciones ilícitas o malintencionadas que

comprometan la disponibilidad, autenticidad, integridad y confidencialidad de los datos almacenados o transmitidos".

- **Seguridad de la información:** "La confianza en que los sistemas de información están libres y exentos de todo peligro o daño inaceptables".
- **Dimensiones de la seguridad (ACIDT):** Es necesario proteger la Autenticidad, Confidencialidad, Integridad, Disponibilidad y Trazabilidad.
- **Activos:** "Recursos del sistema de información o relacionados con este, necesarios para que la organización funcione correctamente".

Metodologías y Estándares

- **MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información):** "Elaborada por el Consejo Superior de Administración Electrónica... para minimizar los riesgos de la implantación y uso de las TIC".
- **ISO/IEC 27001:** Se basa en el "Ciclo Deming (PDCA): Plan, Do, Check, Act".
- **ISO/IEC 27033:** "Dedicada a la seguridad en redes, consistente en 6 partes: conceptos generales, directrices de diseño, escenarios de referencia, gateways, VPNs y redes IP Wireless".
- **Normativa (ENS - RD 311/2022)**
 - **Dimensiones del ENS** (Disponibilidad, Autenticidad, Integridad, Confidencialidad y Trazabilidad).



- **Categorías del Sistema** (Básica, Media, Alta), que dependen del impacto de un incidente.

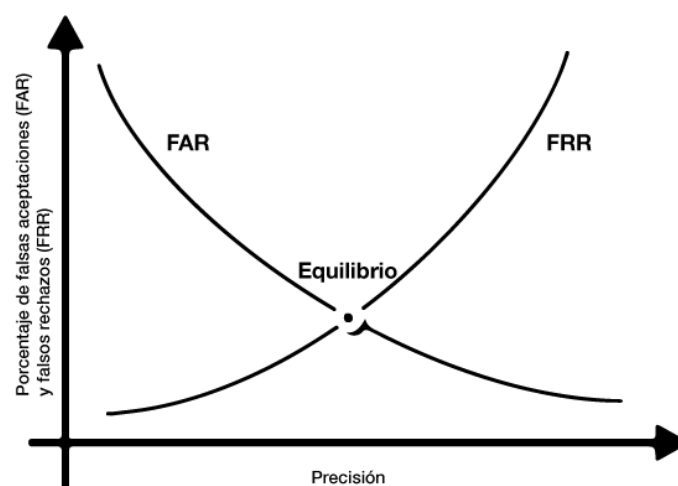
Enfoque CPS: El tribunal suele preguntar por la definición exacta de las dimensiones. Un distractor común es afirmar que la **disponibilidad** se ve afectada por la "interceptación" (falso, es por la **interrupción**). También es frecuente pedir el significado del ciclo PDCA.

Seguridad física y lógica

Seguridad Física

"Conjunto de controles externos al ordenador que tratan de proteger a éste y su entorno de amenazas de naturaleza física como incendios, inundaciones o atentados".

- **Mecanismos:** Control de accesos (tarjetas, biometría), acondicionamiento (HVAC/CRAC) y suministro eléctrico (SAI/UPS).
 - **Errores biométricos:**
 - **Falso Rechazo (Tipo I):** Un usuario legítimo es rechazado (perjuicio al usuario).
 - **Falsa Aceptación (Tipo II):** Un impostor es aceptado (fallo de seguridad crítico).
 - **CER (Crossover Error Rate):** El punto donde ambos errores se cruzan. Cuanto más bajo sea el CER, más preciso es el sistema.



- **Piggybacking o Tailgating:** Incidente en el que un intruso entra en el CPD pasando detrás de una persona autorizada sin que esta lo advierta.
- **Mantrap (Doble puerta):** Sistema físico para evitar el acceso no autorizado tipo piggybacking.



Seguridad Lógica

"Seguridad en el uso de software y los sistemas, la protección de los datos, procesos y programas, así como la del acceso ordenado y autorizado".

- **Autenticación Fuerte:** Sistema que utiliza al menos dos factores (ej. usuario/contraseña y token digital).
- **Control de acceso:** Basado en "algo que se conoce (contraseña), algo que se tiene (tarjeta) y algo que se es (biometría)".

Amenazas y vulnerabilidades

Taxonomía de Amenazas y Ataques

- **Amenaza:** "Causa potencial de un incidente que puede causar daños a un sistema de información o a una organización".
- **Vulnerabilidad:** "Defecto o debilidad en el diseño, implementación u operación de un sistema que habilita o facilita la materialización de una amenaza".
- **Riesgo Residual:** "Riesgo remanente en el sistema después del tratamiento del riesgo, tras la implantación de las salvaguardas".

Tipos de Ataques Específicos

- **Phishing:** "Suplanta la identidad de una entidad de confianza para solicitar a la víctima datos personales que le permitan realizar un fraude".
- **Vishing:** Suplantación a través de llamadas telefónicas.
- **Ransomware:** "Código malicioso para secuestrar datos, en el que el atacante exige un pago por la clave de descifrado" (ej. virus Ryuk).
- **SQL Injection:** "Vulnerabilidad que permite ejecutar código malicioso de acceso o modificación de bases de datos".
- **XSS (Cross-Site Scripting):** Inyección de scripts maliciosos en páginas web para ejecutarlos en el navegador de la víctima.
- **CSRF (Cross-Site Request Forgery):** Obliga al usuario autenticado a ejecutar acciones no deseadas en una aplicación web en la que confía.
- **Sniffing:** Técnica que utiliza un programa (sniffer) para analizar el tráfico. Afecta a la **Confidencialidad**.

Enfoque CPS: CPS suele plantear casos prácticos donde hay que distinguir entre **amenaza** (evento potencial) y **vulnerabilidad** (debilidad técnica). Un distractor recurrente es el **Clickjacking** (secuestro de pulsaciones de ratón).

Técnicas criptográficas y protocolos seguros

Clasificación de la Criptografía

- **Simétrica:** Utiliza la misma clave para cifrar y descifrar (ej. AES, DES, 3DES, IDEA).
- **Asimétrica (Clave Pública):** Utiliza un par de claves, pública y privada (ej. RSA, Diffie-Hellman, DSA, ElGamal).
 - "Dada la clave pública **NO** es posible obtener la privada".

Funciones Hash

- **Definición:** "Se utiliza para garantizar la **integridad** de un mensaje".

- **Propiedad:** "Un proceso para convertir datos en una cadena de longitud fija".

Protocolos Seguros

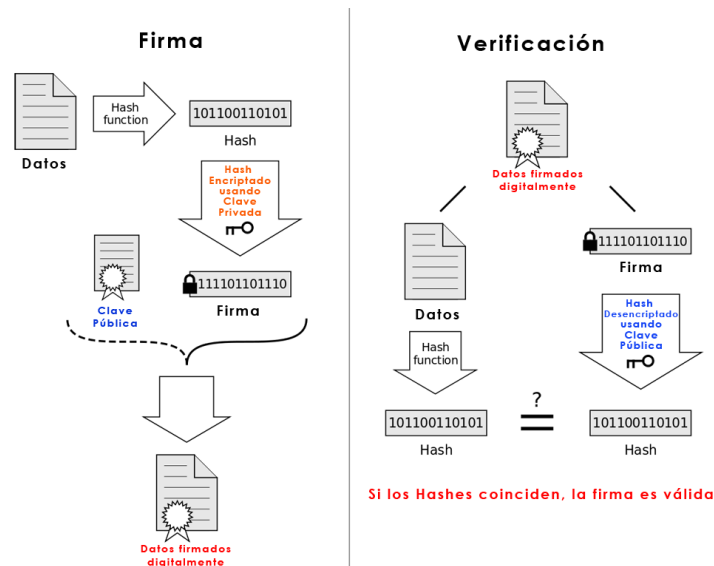
- **TLS (Transport Layer Security):** Evolución de SSL. La versión **TLS 1.3** es la más actual y el proceso de **Handshake** lo inicia el cliente.
- **SSH (Secure Shell):** Sirve para acceder a máquinas remotas con cifrado. Puerto por defecto **TCP 22**.
- **IPSec:** Framework para crear VPNs sobre IP. Protocolos: **AH** (integridad, incompatible con NAT) y **ESP** (confidencialidad).
 - **Modos de funcionamiento:**
 - **Modo Transporte:** Se cifra el contenido, pero la cabecera IP original queda visible (se usa de host a host).
 - **Modo Túnel:** Se cifra **todo el paquete** y se le pone una nueva cabecera IP (se usa para VPNs entre redes).

Cifrado Híbrido y Salting de contraseñas

- **Salting (Salado):** Añade que es la técnica de añadir una cadena aleatoria a la contraseña antes de aplicarle el hash para evitar ataques de **Tablas Arcoíris (Rainbow Tables)**.
- **Cifrado Híbrido:** Es lo que usa TLS. Se usa criptografía asimétrica para intercambiar una clave de sesión y luego criptografía simétrica (más rápida) para los datos.
- **Algoritmos:** Asegúrate de recordar que **DES y MD5** están obsoletos y no son seguros hoy en día.

Mecanismos de firma digital

- **Firma Digital:** "Asegura la **Integridad y No repudio en origen**".
- **Proceso:** "La aplicación cifra el **resumen (hash)** del documento utilizando la **clave privada** del emisor".



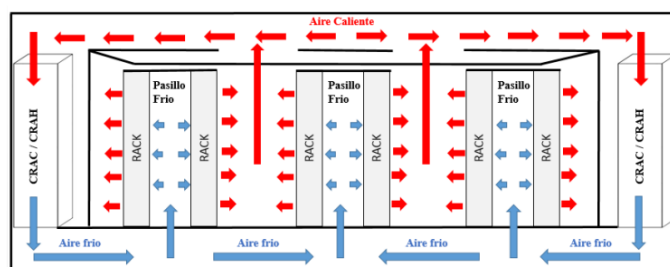
- **Algoritmo ECDSA:** Algoritmo de firma digital basado en curvas elípticas.
- **Formatos de Firma:**
 - **XAdES:** Firma XML Avanzada.
 - **CAdES:** Apropiado para firmar **ficheros grandes**.
 - **PADES:** Específico para documentos PDF.

Enfoque CPS: Una pregunta trampa frecuente es afirmar que la firma digital garantiza la **confidencialidad** del documento completo. La respuesta correcta es que la firma asegura integridad y autenticidad, no necesariamente secreto.

Infraestructura física de un CPD

Acondicionamiento y Racks

- **Rack:** Estructura estandarizada de 19" de anchura. La altura se mide en **U** (**1U = 1.75" o 44.45 mm**).
- **Configuración de pasillos:** "Cold aisle (pasillo frío): partes frontales de los racks enfrentadas".



- **Green CPD:** Requiere unidades **CRAC** (aire acondicionado) eficientes.
- **PUE (Power Usage Effectiveness):** Es la relación entre la energía total que entra al CPD y la energía que realmente consume el equipamiento IT. El valor ideal es **1.0**.

Clasificación (Tiers) según TIA-942

Nivel	Concepto Clave	Característica Literal
TIER I	Básico	Nivel de disponibilidad más bajo.
TIER II	Componentes redundantes	Posee redundancia en componentes clave (refrigeración, energía).
TIER III	Mantenimiento concurrente	Tiene redundancia de componentes, suministro eléctrico y red. Permite mantenimiento sin parada.
TIER IV	Tolerancia a fallos	Tolerante a fallos. Soporta averías críticas sin interrumpir el servicio.

Sistemas de gestión de incidencias y Control remoto

Gestión de Incidencias (ITIL)

- **Incidencia:** "Toda interrupción o reducción de la calidad no planificada del servicio".
- **CAU (Centro de Atención a Usuarios):** Servicio integral de resolución conocido también como "Help Desk".
- **Herramientas:** **BMC REMEDY, Zabbix o Jira.**

Control Remoto

- **Escritorio Remoto:** "Solución que conlleva **mayor riesgo** en la seguridad, ya que la red interna queda expuesta".
- **Recomendación de acceso remoto:** Los privilegios del teletrabajador **NO** deben ser los mismos que en local (principio de mínimo privilegio).

Soluciones del CCN-CERT

- **LUCÍA**: Herramienta para la gestión de incidentes de ciberseguridad.
- **MONICA**: Gestor de logs para responder ante incidentes.
- **CLARA**: Auditoría de cumplimiento ENS en sistemas Windows.
- **EMMA**: Proporciona visibilidad y control sobre la red.
- **MARÍA**: Análisis estático de código dañino.
- **CLAUDIA**: Detección de amenazas complejas (APT) en el puesto del usuario.

Enfoque CPS Final: Memorice las herramientas del CCN-CERT. CPS suele intercambiar las funciones de **LUCÍA** (ticketing/incidentes) con **CLARA** (cumplimiento/auditoría) o **MONICA** (gestión de logs).